MER – Práctica 4: Seguridad en BD (Usuarios, Privilegios, Roles y Auditoría)

MÓDULO A · Seguridad: usuarios, roles y privilegios (Actividades 1 y 2)

USUARIO_BD
- **PK** id_usuario : INT
- **UQ** nombre_usuario : VARCHAR(32)
- host : VARCHAR(255) ('localhost')
- plugin_auth : VARCHAR(64)
- estado_cuenta : ENUM('ACTIVA','BLOQUEADA')
- password_expira : DATE
- fecha_creacion : DATETIME

tiene asignado

USUARIO_ROL (M:N)
- **PK,FK** id_usuario : INT
- **PK,FK** id_rol : INT
- es_rol_default : BOOLEAN
- *FK otorgado_por : INT → USUARIO_BD*
- fecha_asignacion : DATETIME

se asigna a

ROL
- **PK** id_rol : INT
- **UQ** nombre_rol : VARCHAR(32)
- descripcion : VARCHAR(150)
- nivel_acceso : ENUM('ALTO','MEDIO','BAJO')
- fecha_creacion : DATETIME

recibe directo (GRANT)

agrupa (GRANT … TO rol)

PRIVILEGIO_DIRECTO (Act. 1)
- **PK** id_priv_directo : INT
- *FK id_usuario : INT*
- *FK id_privilegio : INT*
- *FK id_objeto : INT*
- with_grant_option : BOOLEAN
- fecha_grant : DATETIME
- fecha_revoke : DATETIME NULL
- estado : ENUM('VIGENTE','REVOCADO')

se otorga como

PRIVILEGIO
- **PK** id_privilegio : INT
- **UQ** nombre : ENUM('SELECT','INSERT', 'UPDATE','DELETE','ALL','EXECUTE', 'CREATE','DROP')
- categoria : ENUM('DML','DDL','ADMIN')
- descripcion : VARCHAR(150)

se otorga como

ROL_PRIVILEGIO (Act. 2)
- **PK** id_rol_priv : INT
- *FK id_rol : INT*
- *FK id_privilegio : INT*
- *FK id_objeto : INT*
- with_grant_option : BOOLEAN
- fecha_grant : DATETIME
- fecha_revoke : DATETIME NULL
- estado : ENUM('VIGENTE','REVOCADO')

sobre

OBJETO_BD
- **PK** id_objeto : INT
- esquema : VARCHAR(64)
- nombre_objeto : VARCHAR(64)
- tipo_objeto : ENUM('TABLE','VIEW', 'PROCEDURE','*')
- **UQ** (esquema, nombre_objeto)

sobre

representa

MÓDULO B · Sistema de la Práctica 1

TABLA_PRINCIPAL (reemplazar por la real)
- **PK** id : INT
- campo_1 : VARCHAR(…)
- campo_2 : DECIMAL / DATE …
- estado : …
- *FK id_tabla_relacionada : INT*
- updated_at : DATETIME

Aquí va la tabla principal de tu sistema (Prácticas 1-3) y, si quieres, las demás tablas.

Cada tabla del sistema es una instancia de **OBJETO_BD** (tipo 'TABLE') sobre la que se dan los GRANT.

dispara

MÓDULO C · Auditoría con triggers (Actividad 4)

genera (lógica, sin FK)

trg_auditoria_au
AFTER UPDATE ON tabla_principal
FOR EACH ROW → INSERT en auditoria_log
(operacion='UPDATE',
dato_anterior=JSON_OBJECT(OLD.*))

registra

AUDITORIA_LOG
- **PK** id : INT AUTO_INCREMENT
- tabla : VARCHAR(64)
- operacion : ENUM('UPDATE','DELETE')
- usuario : VARCHAR(100) ← CURRENT_USER()
- fecha : DATETIME ← NOW()
- dato_anterior : JSON ← OLD.*

registra

trg_auditoria_ad
AFTER DELETE ON tabla_principal
FOR EACH ROW → INSERT en auditoria_log
(operacion='DELETE',
dato_anterior=JSON_OBJECT(OLD.*))

MÓDULO D · Prevención de inyección SQL (Actividad 3)

App Python
formulario / input del usuario

concatena

ANTES (vulnerable)
```
f"SELECT * FROM tabla
WHERE id = '{entrada}'"
entrada = ' OR '1'='1
```

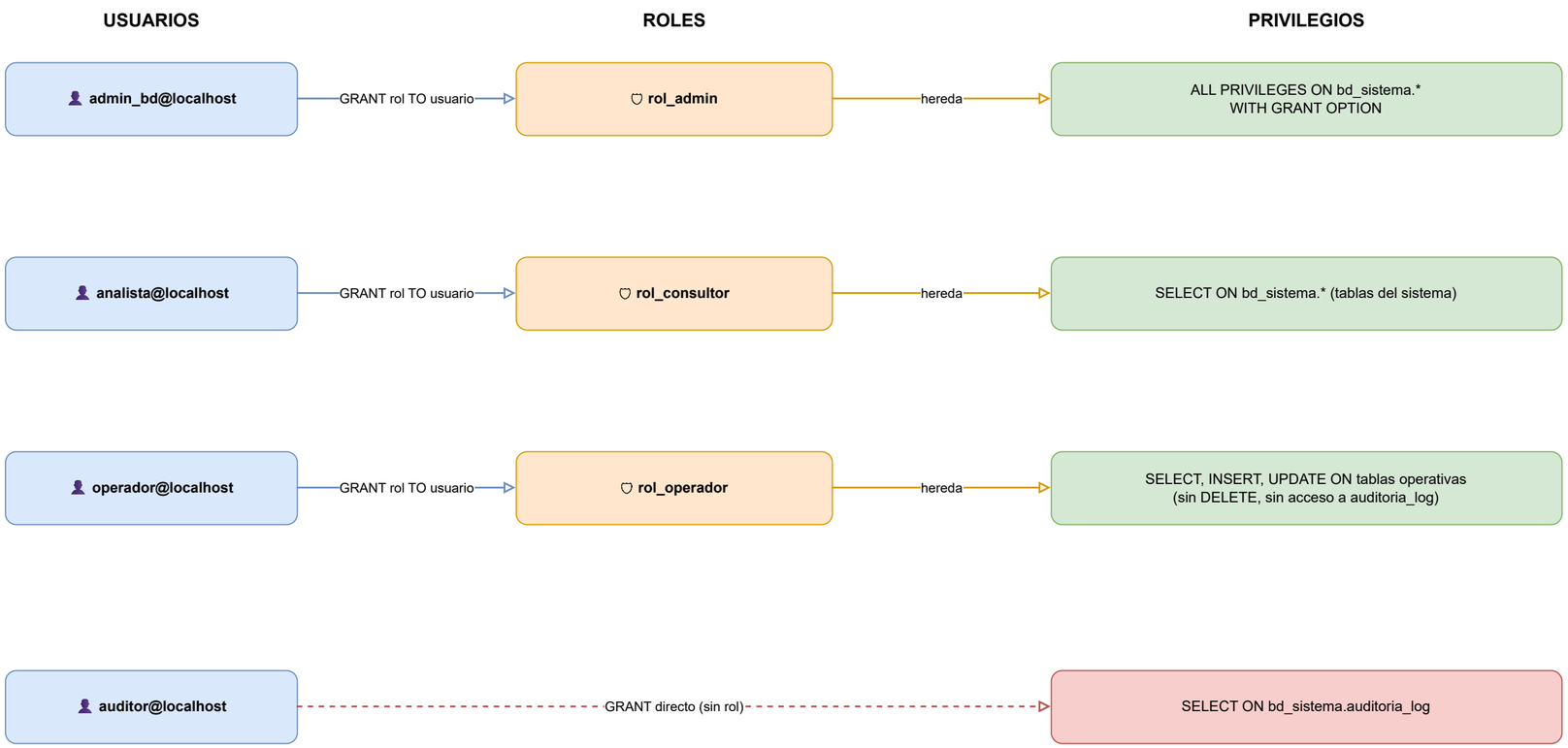
prepared statement

DESPUÉS (parametrizada)
```
cursor.execute("SELECT * FROM tabla
WHERE id = %s", (entrada,))
```

MySQL / MariaDB
conexión con cuenta de mínimo privilegio (operador), nunca root

Diagrama de roles y usuarios – instancias

Línea sólida azul = rol asignado (privilegio heredado) · Línea roja punteada = privilegio directo



Demostración directo vs heredado:
• SHOW GRANTS FOR 'auditor'@'localhost'; → aparece el SELECT sobre auditoria_log directamente.
• SHOW GRANTS FOR 'analista'@'localhost'; → solo aparece GRANT rol_consultor; con *USING rol_consultor* se ven los privilegios heredados.
• Si se hace REVOKE del privilegio al rol, todos los usuarios del rol lo pierden; el privilegio directo no se ve afectado.
• Recuerda SET DEFAULT ROLE para que el rol quede activo al iniciar sesión.

Pruebas de acceso esperadas (Act. 1):
• operador: DELETE FROM tabla → ERROR 1142 (denegado)
• analista: INSERT → ERROR 1142; SELECT → OK
• auditor: SELECT * FROM tabla_principal → ERROR 1142; SELECT del log → OK
• admin_bd: todo OK, puede otorgar permisos

Matriz de permisos por usuario

Usuario	Vía	SELECT	INSERT	UPDATE	DELETE	SELECT auditoria_log	GRANT OPTION
admin_bd	rol_admin (heredado)	✓	✓	✓	✓	✓	✓
analista	rol_consultor (heredado)	✓	✗	✗	✗	✗	✗
operador	rol_operador (heredado)	✓	✓	✓	✗	✗	✗
auditor	directo	✗	✗	✗	✗	✓	✗